Entry Information

ID:
AML.CS0028

Type:
Case-Study

Name:
AI Model Tampering via Supply Chain Attack

URL:
https://atlas.mitre.org/studies/AML.CS0028/

Incident Date:
2023-09-26

Target:
Private Container Registries

Actor:
Trend Micro Nebula Cloud Research Team

Description

Researchers at Trend Micro, Inc. used service indexing portals and web searching tools to identify over 8,000 misconfigured private container registries exposed on the internet. Approximately 70% of the registries also had overly permissive access controls that allowed write access. In their analysis, the researchers found over 1,000 unique AI models embedded in private container images within these open registries that could be pulled without authentication.

This exposure could allow adversaries to download, inspect, and modify container contents, including sensitive AI model files. This is an exposure of valuable intellectual property which could be stolen by an adversary. Compromised images could also be pushed to the registry, leading to a supply chain attack, allowing malicious actors to compromise the integrity of AI models used in production systems.

Attack Procedure:
[AML.T0004] Search Application Repositories: The Trend Micro researchers used service indexing portals and web searching tools to identify over 8,000 private container registries exposed on the internet. Approximately 70% of the registries had overly permissive access controls, allowing write permissions. The private container registries encompassed both independently hosted registries and registries deployed on Cloud Service Providers (CSPs). The registries were exposed due to some combination of:

- Misconfiguration leading to public access of private registry,
- Lack of proper authentication and authorization mechanisms, and/or
- Insufficient network segmentation and access controls

[AML.T0049] Exploit Public-Facing Application: The researchers were able to exploit the misconfigured registries to pull container images without requiring authentication. In total, researchers pulled several terabytes of data containing over 20,000 images.
[AML.T0007] Discover AI Artifacts: The researchers found 1,453 unique AI models embedded in the private container images. Around half were in the Open Neural Network Exchange (ONNX) format.
[AML.T0044] Full AI Model Access: This gave the researchers full access to the models. Models for a

variety of use cases were identified, including:

- ID Recognition
- Face Recognition
- Object Recognition
- Various Natural Language Processing Tasks

[AML.T0048.004] AI Intellectual Property Theft: With full access to the model(s), an adversary has an organization's valuable intellectual property.
[AML.T0018.000] Poison AI Model: With full access to the model weights, an adversary could manipulate the weights to cause misclassifications or otherwise degrade performance.
[AML.T0018.001] Modify AI Model Architecture: With full access to the model, an adversary could modify the architecture to change the behavior.
[AML.T0010.004] Container Registry: Because many of the misconfigured container registries allowed write access, the adversary's container image with the manipulated model could be pushed with the same name and tag as the original. This compromises the victim's AI supply chain, where automated CI/CD pipelines could pull the adversary's images.
[AML.T0015] Evade AI Model: Once the adversary's container image is deployed, the model may misclassify inputs due to the adversary's manipulations.

References

- Silent Sabotage: Weaponizing AI Models in Exposed Containers — https://www.trendmicro.com/vinfo/br/security/news/cyber-attacks/silent-sabotage-weaponizing-ai-models-in-exposed-containers

- Exposed Container Registries: A Potential Vector for Supply-Chain Attacks — https://www.trendmicro.com/vinfo/us/security/news/virtualization-and-cloud/exposed-container-registries-a-potential-vector-for-supply-chain-attacks

- Mining Through Mountains of Information and Risk: Containers and Exposed Container Registries — https://www.trendmicro.com/vinfo/us/security/news/virtualization-and-cloud/mining-through-mountains-of-information-and-risk-containers-and-exposed-container-registries

- The Growing Threat of Unprotected Container Registries: An Urgent Call to Action — https://www.dreher.in/blog/unprotected-container-registries